Government of Canada Gouvernement du Canada



# DAOD 6002-8, Electronic Authentication and Authorization

## Table of Contents

1. Introduction
2. Definitions
3. Overview
4. Operating Principles
5. Compliance and Consequences
6. Responsibilities
7. References

---

## 1. Introduction

**Date of Issue:** 2013-08-15

**Date of Last Modification:** 2023-05-23

**Application:** This DAOD is a directive that applies to employees of the Department of National Defence (DND employees) and an order that applies to officers and non-commissioned members of the Canadian Armed Forces (CAF members).

**Approval Authorities:**

- Assistant Deputy Minister (Finances) / Chief Financial Officer (ADM(Fin)/CFO)
- Chief Information Officer (CIO)

**Enquiries:**

- Director Financial Policy (DFP) for financial policy interpretation and guidance on exercising delegated financial authorities when using electronic authentication and authorization (EAA)
- Director Information Management Engineering and Integration (DIMEI) for EAA information technology (IT) requirements
- Director Strategy and Programme Oversight (DSPO) for all other enquiries

# 2. Definitions

**audit trail** (*piste de vérification*)

> Refers to all the elements and evidence involved in tracking a complete process including authentication or authorization. Elements and evidence include delegation of authority matrices, user profiles and any data and files required to reconstruct the sequence of events and transactions processed. (Defence Terminology Bank record number 35638)

**certification authority** (*autorité de certification*)

An entity that is responsible for the operation of one or more servers used for the issuance and management of Public Key Certificates and Certificate Revocation Lists. (Defence Terminology Bank record number 47945)

**electronic authentication** (*authentification électronique*)

The process by which an individual (a person, an organization or device) is verified as a unique and legitimate user. (Defence Terminology Bank record number 48283)

**electronic authorization** (*autorisation électronique*)

The process by which an authenticated user is granted the capability to render electronic approvals and discharge those authorities in electronic financial transactions. (Defence Terminology Bank record number 48284)

**electronic signature** (*signature électronique*)

Means a signature that consists of one or more letters, characters, numbers or other symbols in digital form incorporated in, attached to or associated with an electronic document. (Subsection 31(1) of the *Personal Information Protection and Electronic Documents Act*)

**financial transaction** (*opération financière*)

Any event, request, action or commitment that has a monetary implication such as the acquisition, disposition or use of assets or resources; the increase or reduction in a liability; or the receipt, payment and disbursement of funds. (Defence Terminology Bank record number 48288)

**identity** (*identité*)

A reference or designation used to distinguish a unique individual, organization or device. (Policy on Government Security, Treasury Board)

**identity management** (*gestion de l'identité*)

The set of principles, practices, processes and procedures used to realize an organization's mandate and its objectives related to identity. (Defence Terminology Bank record number 41457)

**integrity of electronic financial transactions** (*intégrité des opérations financières électroniques*)

Transactions that are appropriately safeguarded against unauthorized access, authority or disclosure, destruction, removal, modification, repudiation, incompleteness and inaccuracy. (Defence Terminology Bank record number 48255)

**secure electronic signature** (*signature électronique sécurisée*)

Means an electronic signature that results from the application of a technology or process prescribed by regulations made under subsection 48(1) of the *Personal Information Protection and Electronic Documents Act*. (Subsection 31(1) of the *Personal Information Protection and Electronic Documents Act*)

**user authentication information** (*information d'authentification de l'utilisateur*)

Includes information to support electronic authentication of a user such as passwords, identifiers, biometrics, shared secrets, usage patterns, etc. (Defence Terminology Bank record number 693848)

# 3. Overview

## Context

**3.1.** The increased automation and digitalization of information technology (IT) services are significantly helping the advancement of the DND and the CAF information management (IM) efforts by eliminating wet-ink signatures and the associated task of scanning signed documents into records management systems, thus ensuring efficient transactions. The need to determine the identity of individuals, systems and entities is crucial in establishing trust in electronic interactions within government and with external partners and allies. EAA is the electronic process that:

a. affixes proof of authentication and authorization to business processes and financial transactions;
b. contributes to the protection of data and information integrity; and
c. ensures that the authorizer can be uniquely identified.

**3.2.** The validity of EAA is based on sound identity management practices that are aligned with the Treasury Board (TB) *Directive on Identity Management* and the *Standard on Identity and Credential Assurance*.

**3.3.** While this DAOD promotes the use of electronic signatures (ESs) and secure electronic signatures (SESs) when appropriate, it does not supersede instances for which legislation or regulations specifically requires a wet-ink signature. The decision to use an ES or SES must be based on the level of risk identified to the business process owner.

**3.4.** The DND and the CAF must ensure that effective controls are in place to preserve the integrity of their electronic business processes, financial transactions and electronic identities. This includes EAA processes provided by IT which may be applied in conjunction with non-IT controls. This allows the DND and the CAF to eliminate wet-ink signatures.

**3.5.** Part 2 of the *Personal Information Protection* and *Electronic Documents Act* (PIPEDA) and the *Secure Electronic Signature Regulations* (SES Regs) provide legal authority for the definitions of ES and SES, and their use and application, as acceptable alternatives to wet-ink signatures within the Government of Canada (GC).

**3.6.** DND and CAF ES and SES are dependent on two key elements:

a. the finalization of business documents in portable document format (PDF); and
b. the availability of a public key infrastructure to support SESs.

**3.7.** In compliance with the TB *Policy on Financial Management* and DAOD 1000-5, *Policy Framework for Financial Management*, ADM(Fin) has been appointed by the Deputy Minister (DM) and Chief of Defence Staff (CDS) as the CFO for the DND and the CAF.

**3.8.** Application of EAA for the purpose of financial transactions is subject to ADM(Fin) financial management policies, directives, instructions, standards, guidelines, manuals, procedures and tools.

**3.9.** Application of EAA for the purpose of business processes is subject to the policies, directives, instructions, standards and guidelines of the applicable business process owner.

**3.10.** This DAOD outlines the requirements to maintain the integrity of electronic transactions and their related electronic authentications and authorizations and should be read in conjunction with the:

a. *DND and CAF IM and IT Policy Framework;*
b. *Financial Management Policy Framework;* and
c. other relevant policies, directives, instructions, standards and guidelines.

## Objectives

**3.11.** The objectives of this DAOD are to:

a. ensure DND and CAF EAA practices conform with applicable GC requirements;
b. establish the common business functions to which ES and SES may be applied; and
c. ensure the integrity of electronic business processes and financial transactions.

## Expected Results

**3.12** The expected results of this DAOD are the:

a. mitigation of risks associated with the implementation of EAA;
b. improved efficiencies in the processing of financial transactions using EAA in support of federal environmental sustainability efforts; and
c. increased implementation of EAA in DND business and CAF and operational processes.

# 4. Operating Principles

## Signatures

**4.1.** The main function of a signature is to provide evidence of the following:

a. the identity of the signatory;
b. the intention of the signatory to make the signature; and
c. the intent of the signatory to be bound by the contents of the document.

**4.2.** Section 2 of the SES Regs provides that an SES in respect of data contained in an electronic document is a digital signature that results from the completion of specific operations. Therefore, from a technical perspective, a digital signature and a SES are essentially the same. See the *Canada Evidence Act* and the SES Regs for additional information.

## Electronic Signatures

**4.3.** An ES is a means of confirming the identity of the author, and the integrity of the document against modification and non-repudiation. Examples of ES include:

a. a scanned handwritten signature on a document or form;
b. user login name and password authentication using an internal application;
c. using a stylus on a tablet or laptop touchscreen to “write” a signature; or
d. user login name and password on a Web site that are coupled with a mouse click on some form of acknowledgment button to capture intent.

**4.4.** The decision to implement an ES or SES for a business process must also consider allowing the use of a wet-ink signature until other ongoing projects supporting the use of ES and SES reach completion.

**4.5.** Level one advisors (L1s), commanders of a command or formation, and business process owners are required to review each process and accommodate the use of ES and SES to the maximum extent. The appropriate authorization by the business process owner must be obtained before implementing the use of ES, SES or both for the applicable business process.

## Secure Electronic Signatures

**4.6** An SES is a reliable means of confirming the identity of the author and the integrity of the document against modification and non-repudiation at a higher assurance level than an ES. An SES must be:

a. unique to the person;
b. under the sole control of the person;
c. used to identify the person;
d. linked to the electronic document in such a way that it can be used to determine if the document has been modified since the signature was applied; and
e. compliant with the SES Regs and PIPEDA.

## Assurance Levels and Trust

**4.7.** An assurance level conveys a level of trust between two or more entities where one entity has agreed to rely on another entity to perform activities or execute processes on its behalf. An assurance level is expressed as a standardized generic level on a scale from one to four. Each assurance level describes the degree of certainty of the identity of the person to another entity.

**4.8.** Identity and credential assurance are critical components of ES and SES and their assurance levels must comply with the *Directive on Identity Management* and *the Standard on Identity and Credential Assurance*.

**4.9.** The assurance level assessment must consider the impact of threats, such as:

a. impersonation, e.g. the signer is not who they claim to be;
b. repudiation, e.g. the signer attempts to deny the authenticity of their ES or SES on a document;

c. integrity, e.g. the data in a document has been changed since the ES or SES was applied; and
d. authority, e.g. the signer does not have the authority to sign for a specified level of authorization.

**4.10.** An ES or SES that is recommended for a given level of assurance may be suitable for any lower level of assurance, i.e., an SES that is suitable for assurance level three can also be used at assurance levels one and two. See the TB *Standard on Identity and Credential Assurance, Guideline on Defining Authentication Requirements* and *Guideline on Identity Assurance* for additional information on identity and credential assurance, authentication and assurance level requirements.

**4.11.** In recognizing certification authorities, the President of the TB has verified and recognized that the DND and CAF designated-public key infrastructure certificate authorities have the capacity to issue medium assurance, i.e. level three, digital signature certificates in a secure and reliable manner. See the TB *Secure Electronic Signature Regulations Recognition Process, Standard on Identity and Credential Assurance, Guideline on Defining Authentication Requirements* and the Information Management Standard (IMS) 6002-1-2, *Management of Enterprise Public Key Infrastructure*, for additional information.

## Legal Advice

**4.12.** Before implementation of an ES or SES, a business process owner must seek legal advice from the Department of National Defence and Canadian Forces Legal Advisor (DND/CF LA) or the Judge Advocate General (JAG) as to any legal constraints on their use of an ES or SES and on the types of signature that may be used.

## ES Uses

**4.13.** An ES may be used in accordance with the direction of DND and CAF system operational authorities if the enhanced level of assurance provided by SES is not required.

**4.14.** See IMS 6002-8-1, *Electronic Authorization Methods and the Financial Administration Manual (FAM)*, for additional information on ES uses.

## SES Uses

**4.15.** An SES must meet the requirements set out in the PIPEDA and SES Regs. An SES is:

a. considered equivalent to a wet-ink signature for any authorization related to requirements under the provision of a federal law;
b. admissible in evidence; and
c. recognizable and can be accepted by third parties outside of the DND and the CAF.

## Electronic Financial Transactions

**4.16.** In accordance with financial policies published by the CFO, the implementation of electronic authorizations in DND and CAF systems in which delegated financial authorities will be exercised must be approved by the CFO.

**4.17.** Before making a recommendation to implement an electronic authorization to the CFO, the applicable L1, commander of a command or formation, or business process owner must obtain an appropriate level of assurance that:

a. risks to the integrity of financial transactions have been properly assessed;

b. the internal controls in the business process are working effectively and as designed, or there are action plans in place to mitigate internal control risks; and
c. individuals with delegated financial spending and financial authorities can be authenticated before and after the processing of the transactions for expenditure decisions.

**4.18.** The CFO has approved the use of SES for electronic approvals for the exercise of:

a. expenditure initiation authority;
b. *Financial Administration Act* (FAA) section 32, section 33 and section 34 authorities; and
c. other authorities included in financial policies published by the CFO, e.g. write-off of debt, deeming of low-value amounts to be nil, and waiver or reduction of administration and interest charges (see A-FN-100-002/AG-006, *Delegation of Authorities for Financial Administration for the Department of National Defence (DND) and the Canadian Armed Forces (CAF)*, for additional information).

**4.19.** Individuals with the appropriate delegated authority can now exercise the above authorities using SES that are provided by the designated-public key infrastructure.

**4.20.** DND employees and CAF members who exercise delegated financial authorities using EAA, or use electronic financial systems making use of EAA, must comply with:

a. sections 76 to 81 of the FAA;
b. relevant TB policies, directives and guidelines; and
c. relevant financial policies issued by the CFO.

## Other EAA Uses

**4.21.** A L1 or commander of a command or formation establishing the use of EAA for a business process within their assigned functional area or for CAF operations must:

a. respect the assigned functional areas of other L1s and commanders of a command or formation; and
b. seek legal advice before applying any ES or SES for that use.

**4.22.** See IMS 6002-8-1 for additional information on the requirements and processes for implementing EAA.

## Information Resources of Business Value

**4.23.** Electronic transactions that require EAA, either by ES or SES, are considered information assets or information resources of business value and are therefore subject to DAOD 6001-1, *Information Management Programme*, and the relevant IM standards, guidelines and supplementary policy instruments.

# 5. Compliance and Consequences

## Compliance

**5.1.** DND employees and CAF members must comply with this DAOD. Should clarification of the policies or instructions set out in this DAOD be required, DND employees and CAF members may seek direction through their channel of communication or chain of command, as appropriate. Managers and military supervisors have the primary responsibility for and means of ensuring the compliance of their DND employees and CAF members with this DAOD.

## Consequences of Non-Compliance

**5.2.** DND employees and CAF members are accountable to their respective managers and military supervisors for any failure to comply with the direction set out in this DAOD. Non-compliance with this DAOD may have consequences for both the DND and the CAF as institutions, and for DND employees and CAF members as individuals. Suspected non-compliance may be investigated. Managers and military supervisors must take or direct appropriate corrective measures if non-compliance with this DAOD has consequences for the DND or the CAF. The decision of an L1 or other senior official to take action or to intervene in a case of non-compliance, other than in respect of a decision under the Code of Service Discipline regarding a CAF member, will depend on the degree of risk resulting from the non-compliance and other circumstances of the case.

**5.3.** The nature and severity of the consequences resulting from non-compliance should be commensurate with the circumstances of the non-compliance and other relevant circumstances. Consequences of non-compliance may include one or more of the following:

a. the ordering of the completion of appropriate learning, training or professional development;
b. the entering of observations in individual performance evaluations;
c. increased reporting and performance monitoring;
d. the withdrawal of any authority provided under this DAOD to a DND employee or CAF member;
e. the reporting of suspected offences to responsible law enforcement agencies;
f. the application of specific consequences as set out in applicable laws, codes of conduct, and DND and CAF policies and instructions;
g. other administrative action, including the imposition of disciplinary measures, for a DND employee;

h. other administrative or disciplinary action, or both, for a CAF member; and
i. the imposition of liability on the part of His Majesty in right of Canada, DND employees and CAF members.

**Note –** In respect to the compliance of DND employees, see the TB *Framework for the Management of Compliance* for additional information.

**5.4.** Wilful failure by a DND employee or CAF member to comply with the FAA may result in charges being laid under that Act or sections 121,122, 322 and 380 of the *Criminal Code*.

**5.5.** A loss of public money or property resulting from the misuse of an EAA by a person may result in the person being liable to pay for the loss.

**5.6.** Failure by a DND or CAF organization to comply with this DAOD may result in limitations or removal of their authorization to manage public money or property.

# 6. Responsibilities

## Responsibility Table

**6.1** The following table identifies the responsibilities associated with this DAOD:

| The … | is or are responsible for … |
|---|---|

| | |
|---|---|
| ADM(Fin) / CFO | • approving the implementation and use of SES for electronic authorizations in the exercise of delegated financial authorities that are included in financial policies issued by the CFO; and<br>• ensuring that appropriate controls are implemented to ensure the integrity, accuracy, completeness and security of financial transactions in the DND and the CAF |
| CIO | • ensuring that ESs and SESs meet the requirements of PIPEDA, SES Regs and relevant government policies, directives, standards and guidelines;<br>• ensuring that key IM and IT internal controls are in place to support the integrity of business processes, financial electronic transactions and related EAAs; and<br>• obtaining an appropriate level of assurance that:<br>  ◦ risks to the integrity of financial transactions have been properly assessed;<br>  ◦ key controls to mitigate the risks are documented; and<br>  ◦ key controls are operating effectively and as designed. |

| | |
|---|---|
| L1s and commanders of a command or formation | • ensuring user authentication information for electronic systems within their organizations, e.g. identifiers and passwords, is appropriately safeguarded and managed;<br>• establishing the use of EAA for their business processes;<br>• managing the risks related to their business processes when using EAA;<br>• identifying the level of risk when using EAA for their business processes;<br>• obtaining an appropriate level of assurance that:.<br>  ◦ risks to the integrity of their electronic transactions using EAA are appropriately assessed; and<br>  ◦ appropriate key controls used to mitigate these risks are documented, implemented as designed and operating effectively in a continuous manner;<br>• obtaining CFO approval before implementing SES for electronic authorizations that exercise delegated financial authorities; and<br>• reviewing and approving electronic forms that use ES or SES and that are managed by their organizations. |

| | |
|---|---|
| business process owners, and programme and service delivery managers | • establishing the use of EAA for their business processes;<br>• managing the risks related to their business processes when using EAA;<br>• identifying the level of risk when using EAA for their business processes;<br>• obtaining an appropriate level of assurance that:<br>  ◦ risks to the integrity of their electronic transactions using EAA are appropriately assessed; and<br>  ◦ appropriate key controls used to mitigate these risks are documented, implemented as designed and operating effectively in a continuous manner; and<br>• obtaining CFO approval before implementing SES for electronic authorizations in the exercise of delegated financial authorities. |
| DND employees and CAF members | • managing and protecting their identity information in a manner that mitigates risks to personal, organizational and national security, and that protects the integrity of DND business and CAF operations;<br>• reporting to the appropriate authorities, in accordance with the FAA, any losses of public money or property involving electronic transactions using EAA, resulting from negligence, lack of controls or criminal acts; and<br>• complying with GC, DND and CAF policies, directives, instructions, standards, guidelines and manuals in respect of ES, SES and EAA. |

# 7. References

## Acts, Regulations, Central Agency Policies and Policy DAOD

- *Access to Information Act*
- *Canada Evidence Act*
- *Criminal Code*
- *Financial Administration Act*
- *Library and Archives of Canada Act*
- *Personal Information Protection and Electronic Documents Act*
- *Electronic Alternatives Regulations for the Purposes of the Federal Real Property and Federal Immovables Act*
- *Secure Electronic Signature Regulations*
- *Framework for the Management of Compliance*, Treasury Board
- *Policy on Financial Management Governance*, Treasury Board
- *Policy on Government Security*, Treasury Board
- *Policy on Internal Audit*, Treasury Board
- *Policy on Results*, Treasury Board
- *Policy on Service and Digital*, Treasury Board
- *Directive on Identity Management*, Treasury Board
- *Directive on Public Money and Receivables*, Treasury Board
- *Directive on Service and Digital*, Treasury Board
- *Government of Canada Guidance on Using Electronic Signatures*, Treasury Board
- *Guideline on Defining Authentication Requirements*, Treasury Board
- Guideline on Identity Assurance, Treasury Board
- *Secure Electronic Signature Regulations Recognition Process*, Treasury Board
- *Standard on Identity and Credential Assurance*, Treasury Board

- *Values and Ethics Code for the Public Sector*, Treasury Board
- DAOD 1000-5, *Policy Framework for Financial Management*
- DAOD 6002-0, *Information Technology*

## Other References

- DAOD 5005-2, *Delegation of Authorities for Civilian Human Resources Management*
- DAOD 6001-1, *Information Management Programme*
- DAOD 6002-2, *Acceptable Use of the Internet, Defence Intranet, Computers and Other Information Systems*
- *Delegation of Authorities for Financial Administration for the Department of National Defence (DND) and the Canadian Armed Forces (CAF)*
- *DND and CAF IM and IT Policy Framework*
- *Financial Management Policy Framework*
- *Financial Administration Manual (FAM)*
- FAM Chapter 1016-2, *Expenditure Planning and Initiation – FAA Section 32*
- IMS 6002-1-2, *Management of Enterprise Public Key Infrastructure*
- IMS 6002-8-1, *Electronic Authorization Methods*
- *IM and IT DAOD, Standards and Guides*, ADM(IM) intranet site
- *IM and IT Policy Instrument Development*, ADM(IM) intranet site
- *Interim Directives, Instructions and Other Correspondence*, ADM(IM) intranet site

Date modified: 2023-05-31